

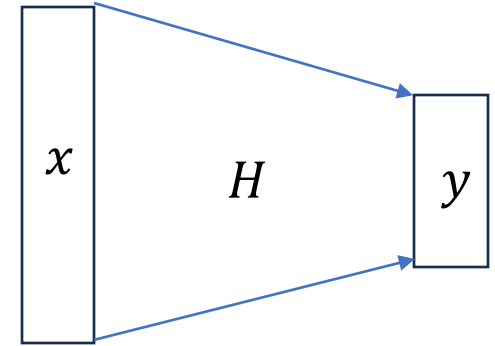
COS 433: Cryptography

Announcements:

- Problem Set 4 due [Wed 11/12](#)

Last time:

1. CRHFs allow for signing long messages with short keys
2. CHRFs based on the discrete log assumption
3. Length extension of CRHFs (Merkle trees)
4. Random Oracle heuristic

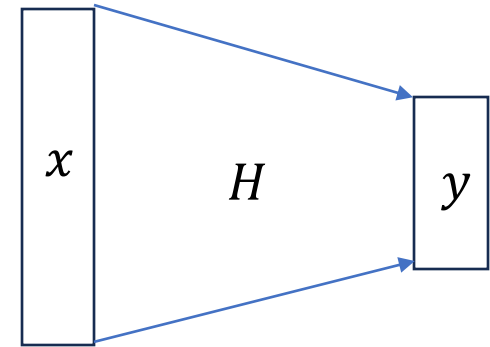


Random Oracle Heuristic

1. Design a crypto scheme that makes black-box use of a hash function H .

2. Prove security “in the random oracle model:”

- H is a uniformly random function
- Adversary is of the form $A^{H(\cdot)}$, making black-box calls to H .



3. **Heuristically instantiate** with a concrete hash function family $\{H_k\}$

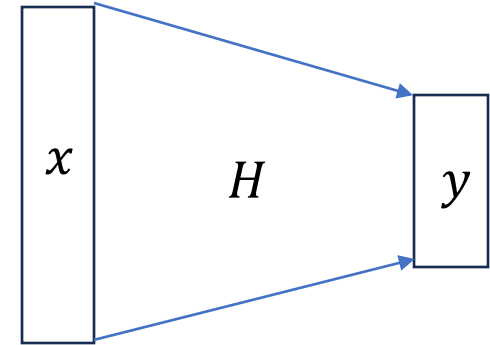
4. **Philosophy** (unproven): carefully designed hash functions should not have non-black-box attacks.

Random Oracle Heuristic

1. Design a crypto scheme that makes black-box use of a hash function H .

2. Prove security “in the random oracle model:”

- H is a uniformly random function
- Adversary is of the form $A^{H(\cdot)}$, making black-box calls to H .

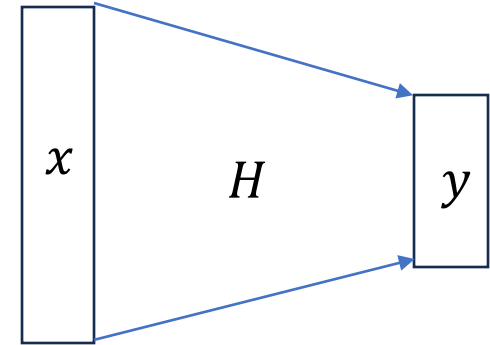


3. **Heuristically instantiate** with a concrete hash function family $\{H_k\}$

4. **Example:** H is a CRHF in the random oracle model (either unkeyed or **salted**:
 $H_k(x) = H(k, x)$)

Random Oracle Heuristic

1. Design a crypto scheme that makes black-box use of a hash function H .
2. Prove security “in the random oracle model:”
 - H is a uniformly random function
 - Adversary is of the form $A^{H(\cdot)}$, making black-box calls to H .
3. **Heuristically instantiate** with a concrete hash function family $\{H_k\}$



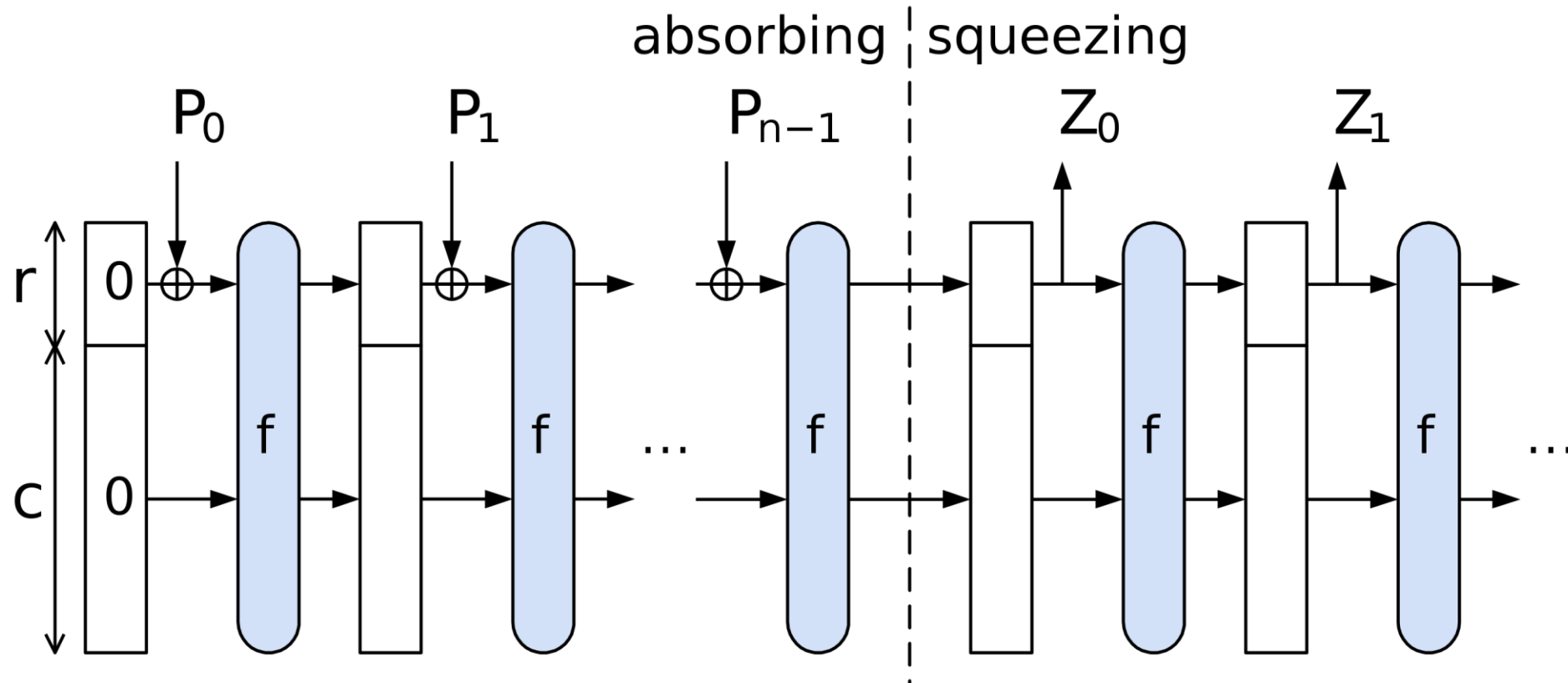
Extremely common/powerful tool for designing **practical** cryptography

But: sometimes unsound, need to be careful

Random Oracle Instantiations (heuristic)

- SHA-2 (2001-)
 - Output length: 256 or 512 bits
 - Fixed-length hash function; use Merkle-Damgard to extend input length
 - This works for collision resistance but not every security property!
 - Need to worry about length extension attacks
- SHA-3 (2015-)
 - Output length: 256 or 512 bits
 - “Sponge construction”
 - Unbounded input length!
- Theoretical: “obfuscated pseudorandom function” (we won’t discuss)

SHA-3: the Sponge Construction



- f : public, AES-like permutation (composition of several simple permutations for 24 rounds)
 - Unlike AES: keyless!
- Proceeds block-by-block
 - Repeatedly: XOR in a block of your input, then apply f
 - Repeatedly: output a block of the current memory contents, then apply f

Applications of Random Oracles

- Two practical signature schemes: RSA and Schnorr/DSA
- Practical, CCA-secure public-key encryption (we won't do this in class)

RSA Signatures

“Textbook” RSA Signatures

$sk = (N, d)$
 $vk = (N, e)$

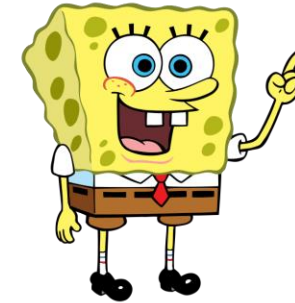


$m \in \mathbb{Z}_N^\times$



(N, e)

$(m, \sigma = m^d \bmod N)$



$\text{Verify}((N, e), m, \sigma) = 1$ if $\sigma^e \equiv m \pmod{N}$

Notes:

- Restricted to $m \in \mathbb{Z}_N^\times$
- **Secure** if the queries and challenge m^* are all **random** and **outside the adversary's control**.

RSA Signatures: “Full Domain Hash”

$sk = (N, d)$
 $vk = (N, e)$



$m \in \{0,1\}^*$



(N, e)

$(m, \sigma = H(m)^d \bmod N)$



$\text{Verify}((N, e), m, \sigma) = 1 \text{ if } \sigma^e \equiv H(m)$

Notes:

- Uses a hash function $H: \{0,1\}^* \rightarrow \mathbb{Z}_N$ (turns out: bounded domain hash function ok)
- This is just **hash-and-sign** applied to textbook RSA!
- But textbook RSA is not secure to begin with, so why is this secure?

RSA Signatures: “Full Domain Hash”

$sk = (N, d)$
 $vk = (N, e)$

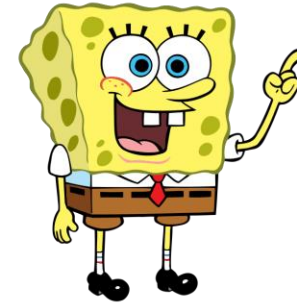


$m \in \{0,1\}^*$



(N, e)

$(m, \sigma = H(m)^d \bmod N)$



$\text{Verify}((N, e), m, \sigma) = 1 \text{ if } \sigma^e \equiv H(m)$

Existential Unforgeability: for all efficient adversaries $A^{\text{Sign}(sk, \cdot)}$



vk

m

$\text{Sign}(sk, m)$



$\Pr_{(sk, vk)} [A^{\text{Sign}(sk, \cdot)}(vk) \rightarrow (m^*, \sigma^*): m^* \text{ not queried and } \text{Verify}(vk, m^*, \sigma^*) = 1] = \text{negl}(\lambda)$

RSA Signatures: “Full Domain Hash”

$sk = (N, d)$
 $vk = (N, e)$

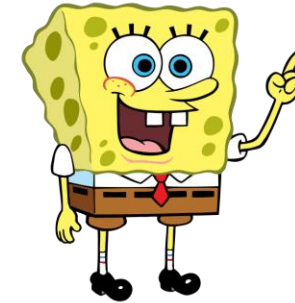


$m \in \{0,1\}^*$



(N, e)

$(m, \sigma = H(m)^d \bmod N)$



$\text{Verify}((N, e), m, \sigma) = 1 \text{ if } \sigma^e \equiv H(m)$

0-time security: for all efficient adversaries A



vk

m^*, σ^*



$\Pr_{(sk, vk)} [A(vk) \rightarrow (m^*, \sigma^*): \text{Verify}(vk, m^*, \sigma^*) = 1] = \text{negl}(\lambda)$

RSA Signatures: “Full Domain Hash”

$sk = (N, d)$
 $vk = (N, e)$

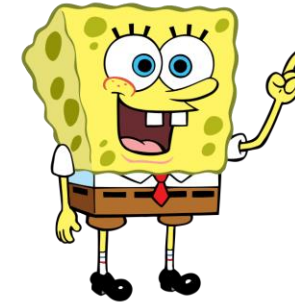


$m \in \{0,1\}^*$



(N, e)

$(m, \sigma = H(m)^d \bmod N)$



$\text{Verify}((N, e), m, \sigma) = 1 \text{ if } \sigma^e \equiv H(m)$

0-time security (random oracle model): for all efficient adversaries $A^{H(\cdot)}$



(N, e)

m

$H(m)$

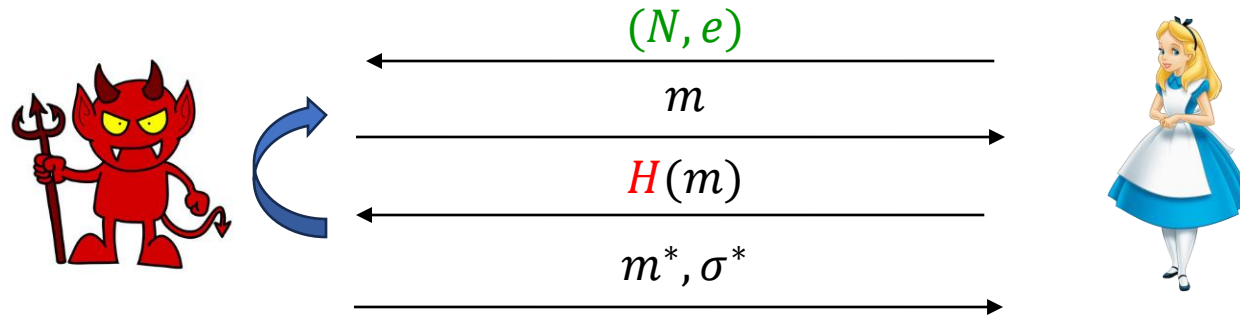
m^*, σ^*



$\Pr_{p,q,e} [A^{H(N, e)} \rightarrow (m^*, \sigma^*): (\sigma^*)^e \equiv H(m^*)] = \text{negl}(\lambda)$

RSA Signatures: “Full Domain Hash”

0-time security (random oracle model): for all efficient adversaries $A^{H(\cdot)}$



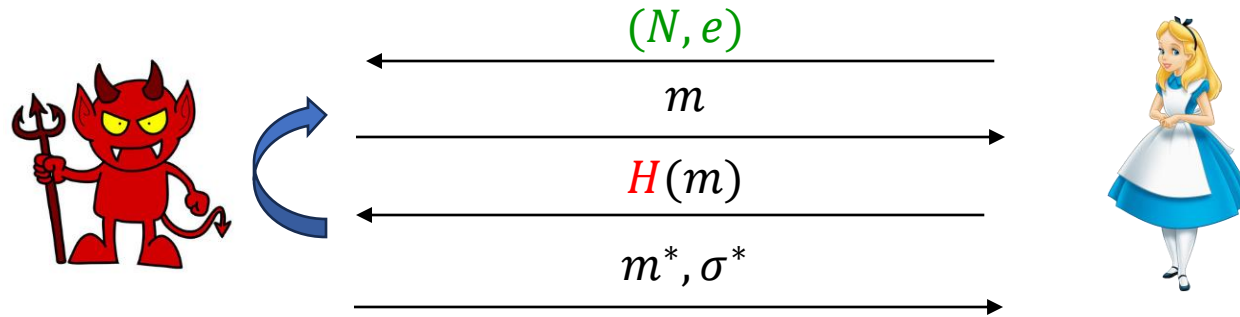
$$\Pr_{p,q,e} [A^{H(N,e)} \rightarrow (m^*, \sigma^*): (\sigma^*)^e \equiv H(m^*)] = \text{negl}(\lambda)$$

Proof (from hardness of RSA):

- We may assume  queries $H(m^*)$
- We can represent H by a poly-length list of pairs (m, y)
- We can break RSA by guessing which query adds m^* to the list.

RSA Signatures: “Full Domain Hash”

0-time security (random oracle model): for all efficient adversaries $A^{H(\cdot)}$



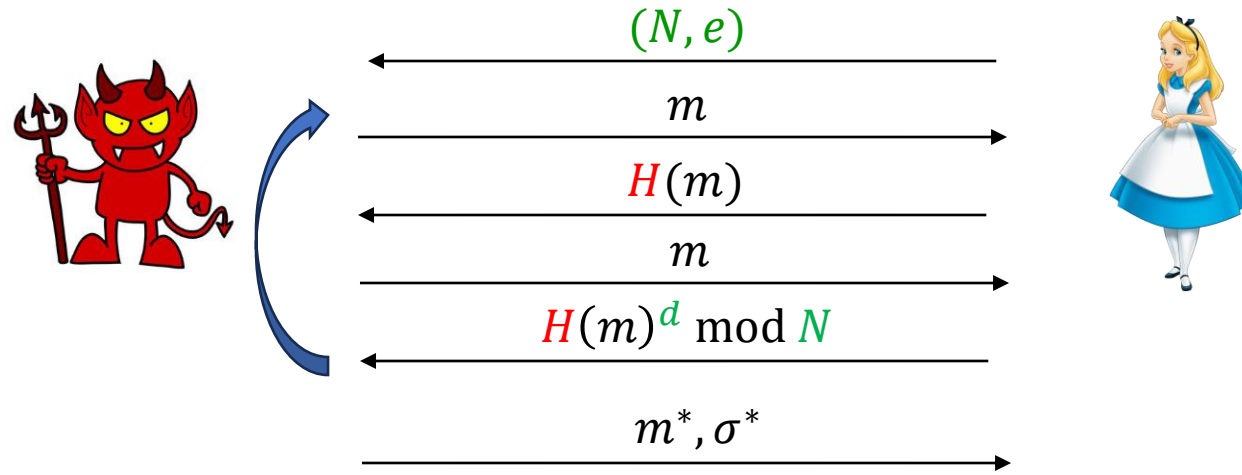
$$\Pr_{p,q,e} [A^{H(N,e)} \rightarrow (m^*, \sigma^*): (\sigma^*)^e \equiv H(m^*)] = \text{negl}(\lambda)$$

Proof (from hardness of RSA):

- Given $(N, e, y = x^e)$: guess index i
- Run , set $y_i = y$
- If  wins with probability ϵ , then  outputs x with probability $\frac{\epsilon}{T}$

RSA Signatures: “Full Domain Hash”

Full security (random oracle model): for all efficient adversaries $A^{H(\cdot), \text{Sign}(\text{sk}, \cdot)}$



$$\Pr_{p,q,e} [m^* \text{ not queried to } \text{Sign}(\text{sk}, \cdot) \text{ and } (\sigma^*)^e \equiv H(m^*)] = \text{negl}(\lambda)$$

Proof idea (from hardness of RSA): signing queries are useless

- Combine the previous proof with the proof of many-time random message security
- Given $(N, e, y = x^e)$: guess index i
- On each m_j query to H (for $j \neq i$) sample $y_j = x_j^e$. Set $y_i = y$.
- Can answer all signing queries with corresponding x_j

Continue next time